專題進度匯報（第二次）

專題名稱： FairChain — 區塊鏈公平遊戲驗證系統

報告日期： 2026 年 10 月

涵蓋範圍： 9 月 17 日上次匯報之後，依助教 9 月 21 日的回饋所做的修正

1. 這次在做什麼

上次匯報後，助教看完報告跟程式碼，給了一份 30 頁的回饋。裡面最重要的一點是：**我們舊版（v2）的設計，玩家可以在下注之前就知道結果。**

原因是舊版的「玩家種子」和「莊家種子」其實都在玩家自己的瀏覽器產生。玩家只要先把兩個種子合起來算一次，就知道會開出什麼，再去押那個結果就好。助教在本機實際試了 3 局，3 局全贏。所以上次報告寫的「兩邊都沒辦法自己決定結果」，在舊版其實不成立。

這段時間主要就是在修這個問題，順便把助教列出的其他問題一起處理。新做法（v3）簡單講是：

> 下注時只送出玩家自己的種子承諾；開獎用的另一半亂數，改成「下注之後下一個區塊的雜湊」。玩家按下注的時候那個區塊根本還不存在，所以沒有人能事先知道結果。

2. 目前整體進度

項目	目前狀態	備註
修正核心漏洞（v3 協議）	已完成	只在本地測試鏈驗證過，**還沒部署到 Sepolia**
合約其他修正	已完成	期限、過期狀態、承諾不可重複使用等
驗證工具	已完成	證據不全時不再顯示「通過」；另做了命令列版本
下注流程的中斷恢復	已完成	還沒用真實錢包做斷線、拒簽等故障測試
自動化測試與 CI	已完成	共 112 個測試，部署前會自動全跑
Slither 重跑	已完成	v3 有 13 筆高危警示，原因已釐清（見 3.6）
技術文件	已完成	新增 3 份、問答集整份重寫
實務專題本	已更新	鏈上實測的部分要等 v3 部署後

		補
v3 部署與 Etherscan 原始碼驗證	**未完成**	需要 Etherscan API key
助教交付物 A：鏈的比較	**未開始**	要讀助教附的官方資料
助教交付物 D：比較實驗	**未開始**	要等 v3 上鏈

3. 這次完成的內容

3.1 修正核心漏洞

合約的下注函式現在**只收玩家自己的承諾**，沒有任何地方能讓別人替玩家塞亂數。合約會記下「開獎區塊 = 下注所在區塊 + 1」，等那個區塊出來後，玩家才公開種子，合約再拿那個區塊的雜湊來算結果。

助教那個 3 局全贏的攻擊，我寫成了一個永久的測試：攻擊者用下注當下能拿到的最新區塊雜湊去猜，連續 40 局。結果沒辦法全贏，而且每一局猜的值都不是真正的結果。

這個方法還是有一個沒辦法消除的風險：**如果玩家把種子偷偷交給「產出開獎區塊的那個出塊者」，兩個人串通**，出塊者就能挑對玩家有利的區塊。所以這個方法只適合小額或測試網。如果真的要上主網，應該改用 Chainlink VRF。這點在文件裡有寫清楚，口試被問到也能回答。

3.2 合約的其他修正

- **期限改用區塊數算**：開獎區塊之後 256 個區塊內可以結算，超過就只能宣告過期。兩個時段不重疊，不會出現「同一時間兩邊都能做、誰先誰贏」的情況（助教 T04）。
- **過期的局有自己的狀態**：以前過期也記成「已結算」，驗證器可能把沒開獎的局誤判成正常局（助教 T05）。
- **同一個承諾不能用兩次**。
- **「贏」的定義統一**：以前合約把 Plinko 0.5 倍（其實是虧）算成贏，頁面又把 1.0 倍（不輸不贏）算成贏。現在全系統統一成「拿回的錢比下注多才算贏」。

3.3 驗證工具

- 結論分成五種：**通過、失敗、未完成、已過期、尚未結算**。缺任何一項證據就顯示「未完成」，不會再像之前那樣部分驗證也顯示通過（助教 T09）。
- 新版合約會把種子跟開獎用的區塊雜湊存在鏈上，所以驗證不用再去翻歷史紀錄，一次就能拿到全部證據。

・會另外向 RPC 查一次那個區塊的雜湊，不直接相信合約自己記的值。

・會重新算賠付金額，多付 1 wei 也抓得到（助教 R02）。

・21 點改成依「補了幾張牌」完整重播整局，不再只比前兩張（助教 T06）。

・可以換別的 RPC 交叉驗證；另外做了**命令列版本**，完全不用經過我們的網站。

3.4 下注流程

・**下注前先把種子存在瀏覽器**。中途重整、拒簽或網路斷掉，回到大廳會看到「未完成的下注」，可以把同一局結算完（助教 R03）。

・已經下注成功的局，重試時只會結算，不會再下一注。

・沒連錢包的時候，畫面會清楚標示「模擬模式」，不會再顯示「真實下注模式」。

3.5 測試

項目	上次	現在
前端測試	28 個	61 個
合約測試	38 個	51 個
本地測試鏈端到端測試	無	2 個

最大的改變是**多了很多「攻擊者做不到什麼」的測試**。上次 38 個測試全過，但 v2 還是有漏洞，因為那些測試都只在檢查「正確的輸入會得到正確的結果」。

另外，以前合約測試是另外寫一份 JS 版本來跟合約比對，助教指出那份 JS 不一定跟網站真正在跑的程式一樣（T01）。現在改成**直接把網站的程式拿來跟合約比**。

CI 也加了一道關卡：push 之後會先跑完全部測試，有一個沒過就不會部署（助教 R08）。

3.6 Slither 重跑的結果（這次學到最多的地方）

重跑後，v3 被標了 **13 筆高危**（類型是「弱亂數」）。我一開始有點緊張，查清楚後發現它指的就是 3.1 講的「出塊者串通」風險，是已知的、有寫進文件的代價，不是新的漏洞。

比較有意思的是另一面：**舊版 v2 用 Slither 掃完是完全乾淨的，但它其實可以被玩家 100% 必贏。**也就是說，「Slither 沒有高危」不能拿來證明系統安全。之前文件跟專題本都有這樣寫，這次全部改掉了。

3.7 文件與專題本

・新增三份文件：

· **助教回饋逐項回應**：每一項的處理狀態、對應的測試，以及我們自己之前寫錯的地方。

· **協議規格書**：誰在什麼時間點知道什麼、每筆交易誰簽誰付錢、資金一定賠得出來的條件等等。

· **設計決策紀錄**：每個選擇的理由與代價。

· 口試問答集整份重寫，舊版有幾題的建議回答是錯的。

· 專題本：摘要、第二章到第五章、附錄都有修改。第四章新增一節，把「發現漏洞 → 修正 → 寫成回歸測試」當成一個實驗來寫。鏈上實測的部分先標「待 v3 部署後補」，沒有沿用舊版的數據。

· 另外，助教回饋裡猜數字顏色機率的數字算錯了：應該是 0 ~ 3 號各 43/256、4 ~ 5 號各 42/256。偏差確實存在，已經修掉，也有寫進回應文件。

4. 畫面

以下截圖都來自**本地測試鏈**（畫面左上角顯示 Hardhat Localhost），不是線上網站，因為 v3 還沒部署到 Sepolia。截圖裡的下注都是在本地測試鏈上實際送出、實際結算的。

圖 1　鏈上驗證：五項證據全部通過



這是驗證本地鏈上第 4 局的結果：輪盤押 17 號，開出 30 號，所以沒中、賠付 0。下面五項驗證分別是：玩家承諾、開獎用的區塊雜湊（另外向節點查詢）、最終隨機數、開獎結果、賠付金額，全部吻合才會顯示「驗證通過」。

圖 2　遊戲頁：右邊從「莊家種子」改成「開獎熵」



以前右邊是「莊家（系統）」，顯示一個蓋住的莊家種子，但那個種子其實就在玩家的瀏覽器裡。現在改成「開獎熵（區塊雜湊）」，並說明下注當下這個區塊還沒產生，所以沒有人能預先知道結果。上方的黃色橫幅標示目前是模擬模式（沒有連接錢包），所以這張圖沒有出現下注金額的面板。

圖 3　遊戲結果：明確標示淨贏、退回本金或淨輸



模擬模式下玩一局 Plinko，落在 1.1 倍，標示為「淨贏」。如果落在 1.0 倍會顯示「退回本金」，0.5 倍則是「淨輸」。

圖 4　本地紀錄驗證：證據不完整就顯示「未完成」



這是驗證上一張那局模擬的結果。因為是模擬局，開獎用的亂數是本機產生的，不是真的區塊雜湊，所以那一項標成「未驗證」，整體結論是「驗證未完成」，不會顯示通過。以前的版本在這種情況下會直接顯示「驗證通過」。

命令列驗證工具的實際輸出

不用開網站，直接指定節點跟合約地址就能驗證，下面是驗證同一局（第 4 局）的輸出：

```
鏈 31337 · FairBet 0xe7f1…0512 · 規則 v3 · Bet #4
輪盤 · 注型 6 · 參數 17 · 注金 0.01 ETH
開獎 輪盤 30 號 · 賠付 0.0 ETH · 開獎區塊 #14
☑ 玩家承諾 = keccak256(seed‖salt)
☑ 熵 = 區塊 #14 的雜湊（向 RPC 獨立取得）
☑ finalRandom = keccak256(seed‖熵)
☑ 開獎結果 = 依規則由 finalRandom 重算
☑ 賠付金額（wei）= 依注型、參數、注金重算
結論：verified
```

5. 時間軸

時間	做了什麼
2026-09-17	上次進度匯報
2026-09-21	收到助教的設計分析與測試回饋（30 頁）
9/21 之後	逐項核對程式碼，確認回饋內容屬實；決定採用「未來區塊雜湊」方案

2026-10-02	完成 v3 合約、前端修改、測試、CI、Slither 重跑、文件與專題本修訂（皆在本地，尚未 commit）
2026-10-03	在本地測試鏈實際操作並截圖，完成本報告
下一步	commit → 部署 v3 到 Sepolia → Etherscan 驗證 → 補鏈上實測

6. 參考資料

這次修正主要參考下面幾份：

1. Coin Flipping by Telephone（Blum, 1983，ACM SIGACT News）

上次也列過這篇，這次才真正搞懂它的前提：兩個人必須**真的是兩個獨立的人**，各自保管自己的秘密。我們舊版兩個種子都在同一個瀏覽器，等於只有一個人，前提根本不成立。

2. On Bitcoin as a Public Randomness Source（Bonneau、Clark、Goldfeder, 2015，IACR ePrint 2015/1015）

討論拿區塊雜湊當亂數的風險：出塊者可以靠放棄出塊來影響結果，代價大約是一個區塊的獎勵。這篇是我們評估「串通風險有多大、適合多少注金」的依據。

3. A Survey of Attacks on Ethereum Smart Contracts（Atzei、Bartoletti、Cimoli, 2017）

它把「拿當前區塊的資料當亂數」列為典型漏洞。我們的做法不一樣：用的是**下注之後**的區塊，而且一定要搭配玩家藏起來的種子。這兩點正好對應它指出的兩個問題。

4. Slither: A Static Analysis Framework for Smart Contracts（Feist、Grieco、Groce, 2019）

就是我們用的那個掃描工具。這次的心得是：它檢查的是程式碼寫法，沒辦法判斷「誰能決定亂數」這種設計層的問題。

5. Chainlink VRF Security Considerations / Ethereum Proof-of-Stake（Chainlink、ethereum.org 官方文件）

前者是之後上主網的替代方案，文件裡也寫了 VRF 自己需要注意的地方，並不是換了就一定比較安全。後者解釋為什麼交易「有 1 個確認」還不等於「最終確定」，這是我們目前還沒處理的部分。

【待確認】中文文獻上次就說要補，這次還沒補。

7. 目前分工

成員	這段時間的工作	實際完成內容	狀態
我	協議修正、合約、前端、測試、文件、專題本	第 3 節列的內容	進行中
其他成員	【待確認】	【待確認】	【待確認】

這次的修正一樣主要是我在做。助教在回饋裡建議了一個三人分工：

- 一人負責協議與合約
- 一人負責鏈的比較與量測
- 一人負責驗證器與對抗測試

助教也提醒「每個人都要能說明自己負責部分的假設與結論，不只是分配簡報排版」。接下來的「鏈的比較」和「比較實驗」都還沒開始，很適合分出去，需要再跟組員確認。

另外，回應文件第七節整理了 10 個問題，像是「下注當下誰知道結果」「為什麼超時沒收修不好舊版」。下次 meeting 前，希望每位組員都能自己回答。

8. 目前遇到的問題

1. v3 還沒部署。 部署需要先把這次的修改 commit，也需要一組 Etherscan API key 才能做原始碼驗證。在 v3 部署之前**不能 push**：push 之後網站會偵測到合約還是舊版，自動把下注關掉，線上就只剩模擬模式。

2.「串通」風險無法消除。 這不是 bug，而是這個方案本身的代價。目前在文件和專題本裡寫清楚適用範圍，之後會跟 VRF 做比較實驗。

3.「最終確定」還沒處理。 結果在交易得到 1 個確認後就顯示，但區塊要大約 13 分鐘才會最終確定。在那之前如果區塊被重組，結果有可能改變，畫面目前沒有區分這兩種狀態。

4. 21 點和猜數字仍然不防作弊。 這兩款有隱藏資訊（莊家的暗牌、密碼），玩家還是能在行動前算出來。要真正修好需要逐張揭露或獨立莊家，工程量很大。目前先在畫面和文件上明確寫出「只是展示」。

5. 助教的交付物 A、D 還沒開始。 A 需要讀不少資料，D 要等 v3 上鏈，而且每個方案要跑 100 局以上。

6. Plinko 的版面小問題（這次截圖才發現）。 結果頁的 17 個槽在一般寬度下會擠不下，最右邊那格會掉到第二排（見圖 3）。不影響結果，但看起來不整齊，還沒修。

7. 分工。 同第 7 節。

9. 下一階段規劃

短期

- 申請 Etherscan API key → commit → 部署 v3 到 Sepolia → 驗證原始碼 → 更新 CI 裡的合約地址
- 在 Sepolia 上實際下注幾局，把鏈上實測補進專題本
- 修掉 Plinko 的版面問題

中期

- 助教交付物 A：比較 Ethereum L1、L2（Rollup）、非 EVM 鏈、許可鏈
- 助教交付物 D：同一個遊戲在 L1 和 L2 上各跑 100 局以上；另外比較我們的方案和 VRF。要特別注意，L2 的區塊雜湊安全性跟 L1 不同，要另外分析
- 在畫面上區分「已確認」和「已最終確定」

後期

- 21 點、猜數字的隱藏資訊處理
- 專題本定稿
- 口試準備（回應文件第七節的 10 個問題）

10. 目前成果總結

這次最大的收穫是被助教抓到一個很根本的問題：舊版玩家可以在下注前就知道結果。而且這個問題在我們原本的 38 個測試、Slither 掃描和期望值實驗裡全部都沒出現。

現在已經改成 v3：玩家下注時開獎區塊還沒產生，沒有人能先選結果。這個攻擊也寫成了永久測試。驗證工具、下注流程、測試和文件都跟著修正，整體測試從 66 個增加到 112 個，部署前會自動跑。

剩下最急的是把 v3 部署到 Sepolia 並完成原始碼驗證，然後補上鏈上實測。之後要做助教要求的鏈比較和比較實驗，這部分比較適合分給組員一起做。